FIAP ON

GESTÃO DE RISCOS E VULNERABILIDADES

TRATAMENTO E RESPOSTA a incidentes

ABNER NETTO

06

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 6.1 – Incidentes reportados por ano.....6
Figura 6.2 – Grupos de segurança e resposta a incidentes brasileiros.....9

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE QUADROS

Quadro 6.1 – Ferramentas para análise de log 21

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 6.1 – Comando nslookup 16
Comando de prompt 6.2 – Comando nslookup em processo reverso 16
Comando de prompt 6.3 – Whois do domínio fiap.com.br 17
Comando de prompt 6.4 – Exemplo de comando traceroute 18
Comando de prompt 6.5 – Exemplo de comando dig 18
Comando de prompt 6.6 – Exemplo de log do *firewall* da Fortigate 20

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

6. TRATAMENTO E RESPOSTA A INCIDENTES 6
6.1 Incidentes de segurança 7
6.2. Tratamento de incidentes 8
6.2.1 CSIRT 8
6.2.2 Notificação de Incidentes 10
6.2.3 Resposta a Incidentes 12
6.2.4 Coleta de evidências 14
6.3 Técnicas para Análise de Incidentes 15
6.3.2 Identificação de contatos 15
6.3.1 Análise de LOGs 19
REFERÊNCIAS 22

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

6. TRATAMENTO E RESPOSTA A INCIDENTES

A cada ano aumenta o número de ameaças à segurança da informação. A Kaspersky, fornecedora de soluções de antivírus, detectou 346 mil novos *malwares* por dia em 2018. Uma estatística que era de 70 mil novos arquivos por dia em 2011. Fora os *malwares* (vírus, *trojan, ransomware*), temos falhas de configuração em *softwares*, erros de programação, falhas humanas, entre outras vulnerabilidades que afetam significativamente a segurança da informação e contribuem para o aumento do número de incidentes.

Acredita-se que 70% das organizações não reportem incidentes de segurança da informação, geralmente por medo de a equipe de TI ser punida, o que elevaria esse número. No Brasil, o Comitê Gestor da Internet, por meio do NIC.br, mantém um Grupo de Resposta a Incidentes de Segurança – CERT.br – que é responsável por tratar incidentes de segurança em computadores que envolvam redes conectadas à Internet no Brasil. O CERT.br "atua como um ponto central para notificações de incidentes de segurança no Brasil, provendo a coordenação e o apoio no processo de resposta a incidentes e, quando necessário, colocando as partes envolvidas em contato.

Figura 6.1 – Incidentes reportados por ano
Fonte: CERT.br, adaptado por Fiap (2016)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Na figura “Incidentes Reportados por Ano”, podemos visualizar a quantidade de incidentes de segurança reportados ao CERT.Br por ano, com destaque para o ano de 2014, quando houve um aumento expressivo devido à Copa do Mundo no Brasil.

Para as organizações manterem seus ambientes de TI seguros é necessário que todo o incidente de segurança seja analisado e tratado para evitar possíveis consequências ao negócio.

A norma ISO/IEC 27002 define algumas diretrizes para gestão de incidentes de segurança na informação, em sua seção 16:

- Preparação e planejamento de resposta a incidente.
- Monitoração, detecção, análise e notificação de incidentes e eventos de segurança da informação.
- Registros das atividades de gerenciamento de incidentes.
- Manuseio de evidências forenses.
- Avaliação e decisão dos eventos de segurança da informação, bem como suas fragilidades.
- Respostas, incluindo aquelas relativas a escalação, recuperação controlada de um incidente e comunicação as pessoas ou organizações, internas e externas.

6.1 Incidentes de segurança

Um incidente de segurança pode ser definido como qualquer evento adverso, confirmado ou sob suspeita, relacionado à segurança de sistemas de computação ou de redes de computadores (CERT.br, 2016). Alguns exemplos de incidentes incluem:

- Infecção por vírus.
- Sequestro de informações (*ransomware*).
- Roubo de informações confidenciais.
- Acesso a websites indevidos etc.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Os incidentes de segurança podem ser classificados, basicamente, em duas categorias: incidentes internos e incidentes externos (CERON, 2014).

Os incidentes externos caracterizam-se por serem originados fora da rede da instituição, ou seja, externos ao domínio administrativo da instituição. Por exemplo, uma varredura por vulnerabilidades a um servidor da corporação. Ao passo que os incidentes internos se referem a todo tipo de incidente originado na própria rede da instituição, como, por exemplo, roubo de informações confidenciais e a má utilização dos recursos disponíveis.

Os incidentes de segurança internos podem ser mais dispendiosos que os incidentes externos. Esse tipo de incidente possui uma maior probabilidade de sucesso, pois se pressupõe que o atacante possua prévio conhecimento da estrutura interna da organização.

6.2. Tratamento de incidentes

Entende-se por tratamento de incidentes o processo de identificar, mitigar e prevenir incidentes de segurança da informação. O principal objetivo do processo de resposta a incidentes de segurança é minimizar o impacto de um incidente e permitir o restabelecimento dos sistemas o mais rápido possível (CERON et. al., 2014).

6.2.1 CSIRT

CSIRT é um acrônimo internacional para designar um Grupo de Resposta a Incidentes de Segurança (Computer Security Incident Response Team), responsável pelo tratamento de incidentes de segurança da informação em organizações públicas ou privadas.

A redução do impacto de um incidente é consequência da agilidade de resposta e da redução do número de vítimas, sendo assim, o CSIRT desempenha um papel importante (HOEPERS e STEDING-JESSEN, 2016):

- Auxilia a proteção da infraestrutura e das informações;
- prevê incidentes e conscientizando sobre os problemas;

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- auxilia detecção de incidentes de segurança;
- responde a incidentes;
- retorna o ambiente ao estado de produção;
- entende “o que” aconteceu, não “quem” originou a ação.

O time de resposta a incidentes de segurança deve ser constituído por um grupo cuidadosamente selecionado que, além de analistas de segurança, possa incluir representantes legais e integrantes do departamento de relações públicas (CERON et al, 2009).

Para obter sucesso nesse processo, a confiabilidade é a chave, sendo assim, o CSIRT nunca deve divulgar dados sensíveis ou expor vítimas, por exemplo. Como na maioria das vezes, utilizam-se as ferramentas da investigação e da perícia forense, o CSIRT acaba por auxiliar nas investigações posteriores. Quando identificado um crime, cabe atuar na preservação de evidências.

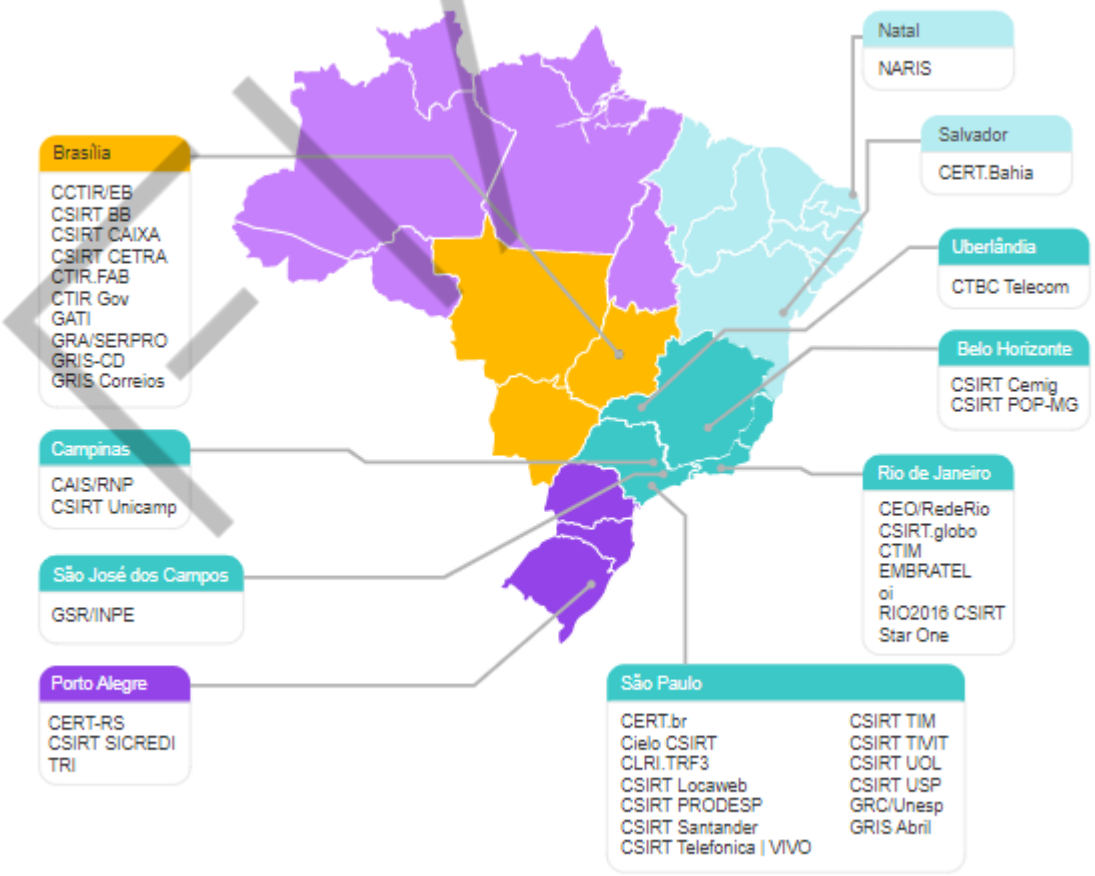

Figura 6.2 – Grupos de segurança e resposta a incidentes brasileiros
Fonte: CERT.br (2016)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

No Brasil, o tratamento de incidentes teve seu início logo após a abertura comercial da Internet em agosto/1996, quando o relatório "Rumo à Criação de uma Coordenadoria de Segurança de Redes na Internet Brasil" foi publicado pelo Comitê Gestor da Internet (CGI.br). Quase um ano depois, em junho/1997, foi criado o CERT.br (inicialmente chamado de NBSO – NIC BR Security Office). Hoje, conta-se com mais de 40 grupos espalhados pelo Brasil (vide Figura “Grupos de Segurança e Resposta a Incidentes Brasileiros”), a lista completa com informações de contato pode ser consultada no site do CERT.br em: <https://www.cert.br/csirts/brasil/>.

6.2.2 Notificação de Incidentes

Parte indispensável do processo de tratamento de incidentes, a notificação é uma atividade de grande importância, visto que (CERT.br, 2016):

- **Melhora a capacidade de detecção de incidentes**: muitas instituições descobrem que estão comprometidas apenas quando são notificadas por terceiros. Notificar incidentes pode ajudar a identificar problemas e prevenir novas ocorrências.
- **Contribui para a segurança geral da Internet:** ao notificar uma tentativa de ataque da qual foi vítima, ao invés de apenas mitigá-la, busca-se a solução do problema e demonstra-se comprometimento com questões de segurança.
- **Pode ajudar a conter danos e prejuízos:** notificações podem ser instrumentos eficazes na mitigação de incidentes e na contenção dos prejuízos, por exemplo, em casos de fraudes.
- **Permite gerar estatísticas, correlacionar dados e identificar tendências** que ajudarão a elaborar recomendações e materiais de apoio, a orientar campanhas pela adoção de boas práticas e a estabelecer ações em cooperação.

Todos os colaboradores ou terceiros devem ser alertados sobre sua responsabilidade de notificar qualquer evento de segurança informação, o mais rápido possível, como o mau funcionamento de um sistema ou outro comportamento inesperado, que pode ser um indicador de um ataque ou violação na segurança. A

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

norma ISO/IEC 27002 lista as seguintes situações a serem consideradas para notificar um incidente de segurança da informação:

- Controle de segurança ineficaz.
- Violação da disponibilidade, confidencialidade e integridade da informação.
- Erros humanos.
- Não conformidade com políticas ou diretrizes.
- Violações de procedimentos de segurança física.
- Mudanças descontroladas de sistemas.
- Mau funcionamento de software ou hardware.
- Violação de acesso.

O mecanismo de notificação deve ser fácil, acessível e disponível, como um número de telefone (ramal interno) ou um e-mail. O CERT.br recomenda que as organizações mantenham um e-mail *security@...* direcionado para a equipe do CSIRT, como forma de notificação de incidentes.

CERON (2014) recomenda algumas boas práticas de notificação de incidentes de segurança:

- Quando reportar um e-mail para outros países, recomenda-se a utilização do idioma inglês. Mesmo em países onde o inglês não é a língua oficial, os times nacionais estão preparados para entender o idioma.
- Deixar evidentes as informações básicas do incidente reportado. Por exemplo, ao reportar uma página falsa, é importante deixar a URL em questão visível, ou seja, destacada no texto.
- O assunto da notificação deve ser claro o suficiente para o analista inferir o conteúdo reportado. Evite assuntos genéricos, do tipo: “pedido de ajuda”, “incidente de segurança” ou ainda “urgente”.
- O uso de modelos de mensagens é bastante comum para notificar incidentes de segurança, no entanto, prefira mensagens objetivas e direcionadas, por serem mais efetivas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- A resolução de um incidente passa por uma colaboração entre equipes. Recomenda-se armazenar os contatos que foram efetivos e prestativos no processo de resolução de problemas, que podem ser úteis em um momento de crise.
- Para a troca de informações por e-mail, prefira a utilização de texto sem formatação. Deve-se evitar enviar notificações em formato HTML ou ainda informações contidas em imagens (captura de tela).

6.2.3 Resposta a Incidentes

A devida resposta aos incidentes de segurança é um processo complexo e dispendioso para as equipes de segurança da informação, por isso, o CSIRT tem papel fundamental na diminuição do número de incidentes (CERON et al., 2009).

O principal objetivo do processo de resposta a incidentes de segurança é minimizar o impacto de um incidente e permitir o restabelecimento dos sistemas o mais rápido possível.

Para Ceron et al (2009), um bom plano de resposta a incidente passa pela definição de uma política de segurança que define claramente as etapas do processo que devem ser seguidos quando um incidente ocorrer. O processo de resposta a incidentes deve ser produto de uma sinergia entre as diferentes equipes organizacionais, agregando níveis gerenciais a níveis técnicos, ao passo que a sua implementação é de responsabilidade do time de resposta a incidentes, ou CSIRT.

A definição de um processo de resposta a incidentes deve observar alguns princípios que norteiam a concepção de um sistema de tratamento a incidentes (Wyk; Forno, 2001):

- **Identificação:** cabe a esta etapa detectar ou identificar de fato a existência de um incidente de segurança. Para isso, a equipe pode basear-se em notificações externas ou num conjunto de ferramentas de monitoração de rede, como um IDS (sistema de detecção de intrusão). Os esforços da equipe concentram-se em identificar os sintomas do ataque e suas características, observando a severidade do incidente, ou seja, o quanto a estrutura de negócios da instituição é afetada. Recomenda-se também que

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

o time de resposta a incidentes implemente uma base de conhecimento de incidentes, isto é, um conjunto de registros de incidentes passados. Essa base de conhecimento será útil para levantar informações iniciais dos incidentes em andamento, assim como sintomas e características.

- **Coordenação:** após identificar a existência de um incidente e suas consequências na etapa anterior, cabe à equipe identificar os danos causados pelo incidente em questão. A avaliação dos sintomas coletados permite diagnosticar de forma preliminar a causa do problema ou, pelo menos, inferir algumas conclusões que serão úteis para determinar a ação a ser tomada. De forma conclusiva, esta etapa sugere possíveis ações que possivelmente podem resolver o incidente em andamento.
- **Mitigação:** o objetivo desta etapa é isolar o problema e determinar a extensão dos danos com a implementação da solução delineada na etapa anterior. Além de utilizar procedimentos para isolar o incidente, evitando a propagação do ataque, a equipe também busca restabelecer o sistema, mesmo que seja com uma solução temporária, até que a solução definitiva seja implementada.
- **Investigação:** nesta etapa, o time de resposta concentra-se em coletar e analisar as evidências do incidente de segurança. O processamento de evidências, como registros, arquivos de pacotes capturados e até mesmo entrevistas com os responsáveis, é muito importante para a resolução de futuros incidentes com características semelhantes.
- **Educação:** esta etapa consiste em avaliar o processo de tratamento de incidentes e verificar a eficácia das soluções implementadas. As lições aprendidas durante todo o processo devem ser propagadas para toda a equipe, descrevendo formas de obter melhores resultados e até mesmo recomendações aos usuários.

Para uma correta resposta a incidentes, a norma ISO/IEC 27002 descreve alguns itens que precisam ser observados:

- Coleta de evidências, tão rápido quanto possível, logo após a ocorrência.
- Condução de uma análise forense de segurança da informação.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Escalação.
- Garantia de que todas as atividades de respostas envolvidas sejam adequadamente registradas para análise futura.
- Comunicação da existência de incidente de segurança da informação ou qualquer detalhe relevante para pessoas internas ou externas, bem como organizações que precisam tomar conhecimento.
- Tratamento das fragilidades de segurança da informação encontradas que causem ou contribuam para o incidente.
- Uma vez que o incidente tenha sido tratado de forma bem-sucedida, encerrá-lo e registrá-lo formalmente.

Após a análise e resolução dos incidentes de segurança, os conhecimentos obtidos devem ser usados para reduzir a probabilidade ou o impacto de incidentes futuros. Como a melhoria de controles existentes ou a criação de controles adicionais para diminuir a frequência, dano e custo de futuras ocorrências. Os conhecimentos obtidos, considerando o devido cuidado aos aspectos de confidencialidade, podem ser usados para treinamentos de conscientização de usuários, como exemplos do que pode acontecer, como responder a tais incidentes e como evitá-los no futuro.

6.2.4 Coleta de evidências

Durante o processo de tratamento e resposta a incidentes podem surgir suspeitas de um crime cibernético, nesse caso, cabe à equipe do CSIRT coletar evidências para questões legais ou disciplinares que possam surgir após o incidente.

Conforme a ISO/IEC 27002, o processo de evidências prevê a identificação, coleta, aquisição e preservação das informações, de acordo com diferentes tipos de mídia e dispositivos, levando em conta a:

- Cadeia de custódia.
- Segurança da evidência.
- Segurança das pessoas.
- Papéis e responsabilidades das pessoas envolvidas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Competência do pessoal.
- Documentação.
- Resumo do incidente.

6.3 Técnicas para Análise de Incidentes

Existem várias técnicas e ferramentas que podem ajudar na análise de incidentes. O conhecimento técnico de comandos do sistema operacional, ferramentas on-line e off-line podem ajudar a equipe do CSIRT a identificar contatos para notificação de incidentes, bem como a análise de logs de forma manual ou automatizada.

6.3.2 Identificação de contatos

Identificar os responsáveis envolvidos em um incidente de segurança é uma etapa importante no processo de resposta a incidentes, pois permite a troca de informações sobre a segurança do incidente, melhora o entendimento das atividades relacionadas ao comprometimento, inclui a possibilidade de identificar novas vulnerabilidades e aprimora a segurança como um todo (CERON, 2014).

Algumas etapas que podem ser seguidas pelo CSIRT para obtenção de contatos são:

- Analisar informações contidas na própria notificação (endereço IP, domínio de rede, e-mail etc.).
- Consultar informações no sistema WHOIS.
- Consultar informações em fontes públicas e websites.

Traduzir domínios de redes para endereços IP (domínio > IP)

O comando **nslookup** presentes nos principais sistemas operacionais (Windows/Linux) pode ajudar nesta tarefa:

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
$ nslookup www.fiap.com.br
Non-authoritative answer:
Name:    fiap.com.br
Addresses:  52.203.132.227
            52.203.215.221
```

Comando de prompt 6.1 – Comando nslookup
Fonte: Elaborado pelo autor (2020)

O comando retorna o endereço IP público do domínio fiap.com.br. O mesmo comando pode ser utilizado para realizar o processo inverso:

```
$ nslookup 52.203.132.227
Name:    ec2-52-203-132-227.compute-1.amazonaws.com
Address:  52.203.132.227
```

Comando de prompt 6.2 – Comando nslookup em processo reverso
Fonte: Elaborado pelo autor (2020)

Serviço WHOIS

O WHOIS é um protocolo TCP (porta 43) específico para consultar informações de contato e DNS sobre entidades na internet. Uma entidade na internet pode ser um nome de domínio, um endereço IP ou um AS (Sistema Autônomo).

O serviço WHOIS é mantido pelos grandes operadores e detentores de registros na internet. No Brasil, o responsável é o NIC.br, que mantém o serviço no endereço: <www.registro.br/tecnologia/ferramentas/whois/>.

Uma consulta ao serviço WHOIS do domínio fiap.com.br retorna as informações públicas de contato:

```
Domínio fiap.com.br
Titular   VSTP EDUCAÇÃO LTDA
Documento 11.319.526/0001-55
Responsável    Raul Gustavo Porto Gennari
País BR
Contato do Titular  LAFIA3
Contato Administrativo   LAFIA3
Contato Técnico     LAFIA3
Contato Cobrança    LAFIA3
Servidor DNS   ns-144.awsdns-18.com
Servidor DNS   ns-1566.awsdns-03.co.uk
Servidor DNS   ns-1495.awsdns-58.org
Servidor DNS   ns-1022.awsdns-63.net
Criado    21/08/1997 #53189
Expiração 21/08/2020
Alterado  18/08/2017
Status    Publicado
```

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
Contato (ID) LAFIA3
Nome Laboratorio Fiap
Email     lab@fiap.com.br
País BR
Criado    06/09/2011
Alterado  06/09/2011
```

Comando de prompt 6.3 – Whois do domínio fiap.com.br
Fonte: Elaborado pelo autor (2020)

Além de informações de contato, os dados disponibilizados pelo WHOIS permitem algumas análises. É possível correlacionar informações das entidades e até mesmo identificar domínios suspeitos (CERON, 2014), dentre algumas características:

- Domínio criado ou atualizado recentemente.
- O domínio é escrito de maneira muito similar a um domínio conhecido (por exemplo: bancobradeaco.com.br).
- Domínio é inteiramente gerado por letras e números aleatórios. Pode ser um domínio gerado por malwares.
- Informações dos registradores ou de contato ausentes.
- O domínio está listado em algumas listas de bloqueio ou está associado a atividades maliciosas.

Outras ferramentas que podem ajudar na identificação de contatos são os comandos TRACEROUTE e DIG.

Traceroute

O comando **traceroute** (ou **tracert** no Windows) exibe todos os hosts intermediários entre a máquina na qual o comando é executado e o endereço de destino. A rota pela qual o fluxo de pacotes é encaminhado pode revelar informações de contato de um determinado IP suspeito.

```
Tracing route to 162.159.8.87 over a maximum of 30 hops

  1    17 ms     2 ms    10 ms  192.168.0.1
  2     2 ms     2 ms     1 ms  192.168.28.1
  3     2 ms     2 ms     4 ms  192.168.29.2
  4     3 ms     2 ms     3 ms  192.168.29.17
```

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
  5     5 ms     4 ms     5 ms  132.255.60.125
  6     9 ms     9 ms     6 ms  10.100.100.110
  7     7 ms     7 ms     8 ms  189-38-1-
89.britistelecom.com.br [189.38.1.89]
  8   120 ms   119 ms   120 ms  200.170.81.34
  9   120 ms   119 ms   119 ms  ae3.182.jr03-napbr-
spo.durand.com.br [177.190.108.93]
 10    10 ms    10 ms    10 ms  as13335.saopaulo.sp.ix.br
[187.16.219.111]
 11    10 ms    12 ms    10 ms  162.159.8.87
```

Comando de prompt 6.4 – Exemplo de comando traceroute
Fonte: Elaborado pelo autor (2020)

DIG

O DIG é uma ferramenta via linha de comando utilizada para realizar diversas consultas a servidores DNS, como: endereço de rede (registro A), servidores de e-mails (MX), servidores de nomes (NS), informações de host (HINFO) e outros registros.

Como exemplo, para consultar todos os servidores de e-mails associados a um determinado domínio, utilizamos o comando:

```
$ dig fiap.com.br MX
id 44199
opcode QUERY
rcode NOERROR
flags QR RD RA
;QUESTION
fiap.com.br. IN MX
;ANSWER
fiap.com.br. 299 IN MX 0 fiap-com-
br.mail.protection.outlook.com.
;AUTHORITY
;ADDITIONAL
```

Comando de prompt 6.5 – Exemplo de comando dig
Fonte: Elaborado pelo autor (2020)

Pelo resultado do comando, é possível verificar que os servidores MX da FIAP estão no outlook.com que é um domínio de serviço do Microsoft Office 365.

Existem casos em que não será possível determinar os contatos apropriados usando WHOIS ou as ferramentas listadas, portanto, diante disso, deve-se recorrer a meios alternativos que podem auxiliar de forma indireta a identificar os responsáveis, como redes sociais, fóruns de discussão técnica, informações contidas nos websites etc. (CERON, 2014).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

6.3.1 Análise de LOGs

Os *logs* descrevem eventos registrados por dispositivos ou aplicações, podendo conter diferentes níveis de detalhamento de informações. Geralmente, os logs podem ser utilizados para responder a questões relacionadas a eventos passados, como: identificar tentativas de acesso sem sucesso, instante em que o sistema sofreu instabilidade e informar que o sistema de arquivo está sobrecarregado. No entanto, logs podem ser usados não apenas para revelar informações passadas, mas também para identificar possíveis falhas futuras. Por exemplo, os logs podem identificar que aplicações estão sendo exploradas, permitindo que a equipe avalie se as suas proteções de segurança são adequadas (CERON, 2014). Os logs também são utilizados para a produção de relatórios para monitorar acessos a websites, uso de e-mail, consumo de banda, aplicações bloqueadas etc.

Entretanto, identificar informações relevantes em um arquivo de log é uma tarefa dispendiosa e lenta, principalmente em sistemas com um grande volume de dados. Assim, é importante, para o time do CSIRT, conhecer os diferentes formatos de logs para atuar efetivamente no processo de resposta a incidentes.

Apesar de não haver uma padronização em mensagens de logs (cada fabricante ou dispositivo usa um formato), existem alguns elementos essenciais presentes em toda mensagem de log:

- **Timestamp:** instante em que evento foi registrado.
- **Origem:** sistema que originou a mensagem, geralmente um endereço IP ou nome do host.
- **Dados:** informações sobre o evento gerado. Apesar de não haver uma padronização, pode conter: dados de usuários, dados de aplicações, recursos de sistemas etc.

Os sistemas de log – registros de eventos e notificações – são compostos por diferentes componentes responsáveis por gerar, transmitir e armazenar informações de eventos. Os mais comuns são (CERON, 2014):

- ***Syslog*:** protocolo aberto baseado em UDP, sendo o mais comum mecanismo de log.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Simple Network Management Protocol** (SNMP): utilizado para gerenciamento de redes.
- **Windows Event Log:** formato proprietário da Microsoft, presente na maioria dos dispositivos usando a plataforma Windows.
- **Banco de dados:** algumas aplicações utilizam base de dados remota para armazenar informações de log de maneira estrutura.
- **Protocolos proprietários:** alguns sistemas e aplicações implementam protocolos customizados, até mesmo criptografados, para transferir e coletar informações de eventos. Exemplo a Fortinet, fornecedor de soluções de segurança, com o Security Fabric e o protocolo FortiTelemetry.

No exemplo, é possível visualizar um log em formato texto do *firewall* Fortigate, no qual se trata de um alerta de intrusão via HTTP que foi bloqueado, com origem do IP 219.155.209.156.

```
Message meets Alert condition
The following intrusion was observed:
"Dasan.GPON.Remote.Code.Execution".
date=2020-02-02 time=17:46:36 devname=FG-TESTE devid=FGT60E
logid="0419016384" type="utm" subtype="ips"
eventtype="signature" level="alert" vd="root"
eventtime=1580676396 severity="critical" srcip=219.155.209.156
srccountry="China" dstip=192.168.2.10 srcintf="wan2"
srcintfrole="wan" dstintf="internal" dstintfrole="lan"
sessionid=645764 action="dropped" proto=6 service="HTTP"
policyid=6 attack="Dasan.GPON.Remote.Code.Execution"
srcport=60221 dstport=8081 hostname="127.0.0.1:80"
url="/GponForm/diag_Form?images/" direction="outgoing"
attackid=46083 profile="default"
ref="http://www.fortinet.com/ids/VID46083"
incidentserialno=632457804 msg="applications3:
Dasan.GPON.Remote.Code.Execution," crscore=50
crlevel="critical"
```

Comando de prompt 6.6 – Exemplo de log do *firewall* da Fortigate
Fonte: Elaborado pelo autor (2020)

Devido à complexidade de análise de logs, existem diversas ferramentas especializadas para implementar o processamento de mensagens, incluindo o uso de inteligência artificial.

O quadro “Ferramentas para análise de log” traz algumas ferramentas tradicionais utilizadas por administradores para gerenciar informações de log.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Ferramenta	Descrição
Logcheck	Desenvolvida para analisar automaticamente arquivos de *log* em busca de violações de segurança e atividades não usuais. Para isso, a ferramenta utiliza uma lista de expressões regulares para classificar as mensagens. É possível definir categorias como: violação do sistema, mensagens a ignorar, tentativas de comprometimento e outras.A ferramenta possibilita o agendamento de mensagens de *logs* (hora/dia/semana/mês) permitindo o envio das análises via e-mail.
Swatch	Semelhante ao Logcheck, mas como o diferencial de permitir disparar ações para cada evento classificado. Por exemplo, assim que muitas tentativas de conexão de um determinado IP são detectadas, uma regra de bloqueio pode ser inserida no filtro de pacotes.
OSSEC	Ferramenta de código aberto que inclui agentes para diferentes plataformas com os quais é possível receber informações de sistemas de *logs*, tal como o Syslog.

Quadro 6.1 – Ferramentas para análise de log
Fonte: CERON (2014)

Security Information and Event Management System (SIEM)

Uma solução SIEM permite que os eventos gerados por diversas aplicações de segurança (tais como firewalls, proxies, sistemas de prevenção a intrusão (IPS) e antivírus) sejam coletados, normalizados, armazenados e correlacionados; o que possibilita uma rápida identificação e resposta aos incidentes.

O termo foi criado em 2005, por Mark Nicolett e Amrit Williams da Gartner Group, descrevendo um produto capaz de coletar, analisar e apresentar informações dos dispositivos de segurança de rede; softwares de controle de acesso; gerenciamento de vulnerabilidades; ferramentas de conformidade; logs de sistema operacional, banco de dados e aplicações e, por último, dados de ameaças externas.

Sistemas SIEM pode coletar os mais diversos eventos para análise. A maioria utiliza agentes coletores que podem ser instalados nos diversos sistemas monitorados. Os agentes coletam eventos e os encaminham para um servidor central, o qual implementa técnicas para identificar anomalias, como análise estatística ou análises heurísticas desenvolvidas pelo próprio usuário. Como resultado de uma análise, ações podem ser configuradas a partir da interface de gerenciamento. (CERON, 2014).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

ABNT. **NBR ISO/IEC 27002:2013**: Tecnologia da Informação – Técnicas de Segurança – Código de Prática para Controles de Segurança da Informação. ABNT, 2013.

CERON, J. M; et al. O processo de tratamento de incidentes de segurança da UFRGS. In: **Workshop de Tecnologia da Informação das IFES (3.: 2009: Belém). [Anais..]. Belém: UFPA, 2009.** 2009.

_____. **Tratamento de Incidentes de Segurança.** RNP/Escola Superior de Redes. 2014. Disponível em: <https://pt.scribd.com/doc/241726599/Tratamento-de-Incidentes-de-Seguranca>. Acesso em: 26 fev. 2021.

CERT.br. **Recomendações para Notificações de Incidentes de Segurança.** 2016. Disponível em: <https://www.cert.br/docs/whitepapers/notificacoes/>. Acesso em: 26 fev. 2021.

HOEPERS, C.; STEDING-JESSE, K. **Estratégias para Tratamento e Prevenção de Incidentes de Segurança**. 2016. Disponível em: <https://www.cert.br/docs/palestras/certbr-incidentes-egijur2016.pdf>. Acesso em: 26 fev. 2021.

WYK, K. R. V.; FORNO, R. **Incident Response.** California, USA: O'Reilly Media, 2001.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com